

From Exploit to Patch

Breaking & Fixing: The Full Security Cycle

Ines & Jessy | M1 Computer Science

Based on: ESEC/FSE 2023 & ACM TOSEM 2025



The Security Challenge



The Research Question

How do we turn red-team findings into actionable, automated defenses in CI pipelines?

🔒 **Study 1: Understanding Hackers' Work:** An Empirical Study of Offensive Security Practitioners

Andreas Happe & Jürgen Cito, ESEC/FSE '23

🧠 **Study 2: Software Security Analysis in 2030 and Beyond:** A Research Roadmap

Marcel Böhme, Eric Bodden, Tevfik Bultan, Cristian Cadar, Yang Liu, Giuseppe Scanniello, ACM TOSEM '25



Your Security Journey Today

Act I: Break It with Ines

Real hackers: tools, tactics, bottlenecks & why automation fails

Act II: Harden It with Jessy

From pen-test findings to secure pipelines: tools, ML, and supply-chain defenses

Interactive Moments

Live polls and a wrap-up quiz are waiting for you

Act I: Break It with Ines



- Defense vs. Offense
- 4 Types of Security Tests
- 5 Popular Tools
- Why Humans + Tools = Success

Offense vs. Defense



Defensive

"Build it right" – secure coding, code reviews, prevent bugs



Offensive

"Break it to harden it" – ethical hackers find flaws before criminals

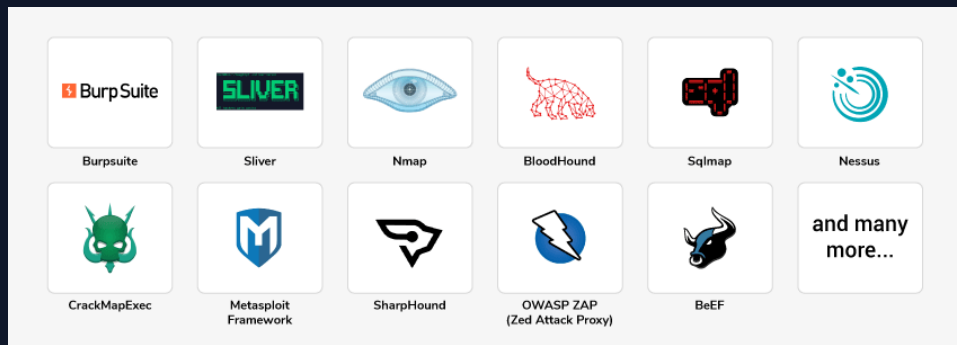
Types of Security Tests

- **Vulnerability Assessment:** Broad scans (2–4 days, high automation)
- **Penetration Test:** Deep dive on one target (5–10 days, manual-intensive)
- **Red-Team Exercise:** Full-scope covert attack (30+ days, large team)



Tools Hackers Use

- **Burp Suite** – web app testing
- **Nmap** – network scanning
- **Nessus** – vulnerability scanning
- **Metasploit** – exploitation framework
- **BloodHound** – Active Directory mapping



Why Human Skill Matters

"A fully automated tool cannot replace a pen-tester."

- No "magic hack button" exists
- Tools generate leads, humans find creative exploits
- Human-in-the-loop ensures context-specific insights



Hacker Pain Points





Poll: Which usually takes longer in a pen-test?

A) Finding issues

B) Proving authorization/access control flaws



Poll: Which usually takes longer in a pen-test?

B) Proving authorization/access control flaws

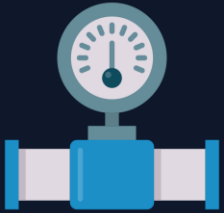
According to interviewees, most time and effort are spent on authorization tests.



Act II: Harden It with Jessy

- Turn Findings into Pipelines
- Security Tools Today
- What Tools Still Miss
- Challenge #1: ML & Security
- Challenge #2: Supply Chain Security

Turn Findings into Pipelines



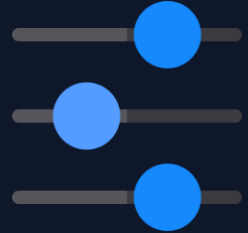
CI Security Gates



Incremental Analysis



Reuse Past Runs



Easier Tool Setup

Security Tools Today



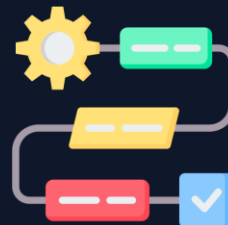
Formal
Verification



Static Analysis



Fuzzing



Dynamic
symbolic
execution



Runtime
Protections

What Tools Still Miss



Memory-Safety
Bias



Hard Non-
Memory Bugs



Weak Specs
& Policies

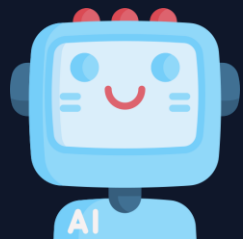


ML Detectors
Don't Generalize

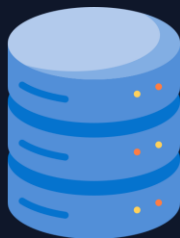


Findings Not
Actionable

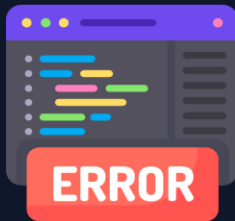
Challenge #1: ML & Security



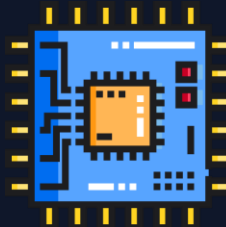
Analyze ML
Systems



Attacks on ML



ML-Generated
Code Risk



ML4SbD &
ML4VD



Sound Evaluation

Challenge #2: Supply Chain Security



Software
Composition
Analysis



Assess
Third-Party Risk



Threats Across
SDLC



Ecosystem-Level
Health



SBOMs &
Governance



Poll: Once we fix known vulnerabilities,
is the system secure?

 **Poll:** Once we fix known vulnerabilities,
is the system secure?

False

We still need to assume breach and design for resilience.



Key Takeaways

- Act I – Break It
 - Offensive tests (scan, VA, pentest, red team) trade scope, depth, and realism.
 - Broken authorization/access control is the hardest, most time-consuming part of web pentests.
- Act II – Harden It
 - Pentest findings can become repeatable CI checks that block risky code changes.
 - Existing tools lag on ML systems and supply-chain risks, not just memory bugs.

Quick Quiz – Did You Catch It?

Test your knowledge with a few questions covering key concepts!



Quick Quiz – Did You Catch It?

Q1: Pen-testers spend most time on authorization testing.

Q2: One automated tool can fully replace manual penetration testing.

Q3: SAST & DAST are both automated security gates in CI/CD pipelines.

Q4: Pen-tester findings should be manually documented in a PDF only.



Quick Quiz – Did You Catch It?

Q1: Pen-testers spend most time on authorization testing.

TRUE – Broken Access Control testing is the most labor-intensive.

Q2: One automated tool can fully replace manual penetration testing.

FALSE – Multiple tools + human expertise are needed.

Q3: SAST & DAST are both automated security gates in CI/CD pipelines.

TRUE – Both scan code statically & dynamically in DevSecOps workflows.

Q4: Pen-tester findings should be manually documented in a PDF only.

FALSE – Findings must feed into CI gates & dev workflows for automation.

Thank You!

Do you have any questions?

Ines & Jessy | M1 Computer Science

Image credits: Freepik, Dewi Sari, Kliwir Art, Design Circle, KMG Design, Smashicons, Icon Home